# Sentinel SOC — AI Strategy Council Report v3

**Third adversarial review · 22 July 2026** Three seats, three vendors, three rounds, votes recorded verbatim.

---

## The finding, stated first

The third council voted **FAILURE_RELOCATED_AGAIN: YES**, unanimously, for the third consecutive review.

All three seats found five defects. Every one was verified against running code, not inferred from documentation. The most severe was not a subtle architectural drift — it was a two-line transposition that **severed the entire background ingestion pipeline**. The API answered `"processing": true` while every queued incident was silently discarded.

That defect was introduced by the V3 remediation itself. So were the other four. This is the pattern the council has now named three times: each remediation pass eliminates the specific bugs it was shown and introduces new instances of the same underlying class.

Since the vote closed, all five findings have been fixed, plus the two items the seats ranked highest among the remaining open work. The fixes are described in Part V with the evidence for each. **The report deliberately does not revise the votes.** The council voted on the code as it stood; presenting a better verdict than the seats actually cast would be precisely the dishonesty this review exists to catch.

---

## How this review was conducted

Three seats, each a different vendor's frontier model, each running as a real CLI agent with filesystem and shell access to the repository. No seat was given the others' answers before writing its own opening.

| Seat | Vendor | Model | Access |
|---|---|---|---|
| Claude Opus 4.8 | Anthropic | `claude-opus-4-8` | Claude Code CLI, headless |
| Codex GPT-5.6-sol | OpenAI | `gpt-5.6-sol` | Codex CLI, headless |
| Antigravity (Gemini) | Google | `agentapi --model=pro` | Antigravity language-server agentapi |

Three rounds: **opening** (independent), **rebuttal** (each seat reads the others), **closing** (votes and 90-day plan). Nine transcripts, 82,360 characters, 15 minutes 45 seconds wall clock. All nine are preserved verbatim in `council/transcript/`.

A fourth seat — Gemini 2.5 Flash via the standalone Gemini CLI — was configured but **could not run**: Google terminated free-tier CLI access for personal accounts (`IneligibleTierError`). It is recorded as unavailable rather than quietly dropped.

### Three conflicts of interest, disclosed to the seats

1. **The Claude seat wrote the V3 remediation it was asked to review.** It was told this and instructed to discount its own warmth toward its design. It did: its closing states *"I cannot be neutral about the lifecycle/type design I authored; discount my warmth toward it accordingly."*
2. **The Antigravity seat is from the vendor whose model wrote the original codebase.** It found the transposition bug that the seat which authored V3 missed across two full rounds. That is the adversarial panel working as intended.
3. **The report you are reading was assembled by the same model that occupies the Claude seat.** The mitigation is that the votes are quoted verbatim and the transcripts ship alongside, so any claim here can be checked against the source.

---

# The recorded votes

| Question | Claude | Codex | Antigravity |
|---|---|---|---|
| Classes actually eliminated | PARTIAL | PARTIAL | PARTIAL |
| Failure relocated again | **YES** | **YES** | **YES** |
| Honest about its own state | **NO** | **NO** | **NO** |
| Safe to run a real pilot | **NO** | **NO** | **NO** |
| Viable commercial product | **NO** | **NO** | **NO** |
| Viable venture company | **NO** | **NO** | **NO** |
| Evidence ledger is a real moat | **NO** | **NO** | **NO** |
| Regression introduced | **YES** | **YES** | **YES** |

Unanimous on all eight. No seat dissented on any verdict; the two recorded dissents narrowed peers' *reasoning* without reversing a vote.

**Biggest single risk**, in each seat's words:

> ***Claude:*** *The product silently ingests nothing and displays zeros while appearing healthy.*

> ***Codex:*** *Customers believe incidents are processing while production work is silently discarded.*

> ***Antigravity:*** *Total pipeline severance causing 100% silent live event loss.*

Three vendors, working independently, converged on the same sentence.

---

# Part I — The five findings

## F1 — Queue tuple transposition (Critical)

`IncidentPriorityQueue.put()` stored `(incident_id, tenant_id, event_data)`; the worker in `api/main.py` unpacked `(tenant_id, incident_id, event_data)`. The two identifiers were swapped on every enqueue.

`repository.get()` was then called with reversed keys, found nothing, and dropped the event.

Effect: **100% of queued incidents were silently abandoned** while the API returned success. The evaluation harness never caught it because it calls `evaluate_event` directly and bypasses the queue entirely.

The immediate cause was a blind global rename of `run_id` to `tenant_id` during the V3 multi-tenancy work — a search-and-replace that did not read what it was replacing.

### F2 — The headline V3 claim was false (Critical)

V3 asserted that the v2 report bug had been made *"structurally unrepresentable"* by the lifecycle state machine. It had not. `check_transition` verified only that a required fact was a **non-empty string**. A fabricated identifier — `report_id: "imaginary"` — satisfied every guard and reached `COMPLETED` with no report row anywhere in the database.

This is the most serious finding in the review, and not because of its blast radius. A false claim of a structural guarantee is worse than a known gap: it tells a customer to stop checking.

### F3 — Metrics counted a table with no writer (High)

`db.metrics()` counted `total_incidents`, `critical_threats`, and every attestation counter `FROM incidents` — a legacy table the repository pattern had replaced. `save_incident` appeared only in the `__all__` export; nothing wrote to it.

Every dashboard aggregate was permanently zero. Worse, `events_processed` and `unverified_events` counted `FROM events`, which *was* populated — so the dashboard displayed live event counts beside zeroed incident totals. Self-contradictory, which for a tamper-evidence product is worse than uniformly blank.

### F4 — `/ingest-event` raised `NameError` (High)

The route referenced an undefined `run_id`. It could not succeed. Three further source-specific routes passed arguments in the wrong order. Same root cause as F1.

### F5 — PostgreSQL was a banner, not a backend (High)

`app/storage/engine.py` parsed `SENTINEL_DATABASE_URL`, resolved a dialect, and printed a startup banner. `translate()` was never called by anything. `db._connect()` invoked `sqlite3.connect()` unconditionally.

Setting a Postgres URL changed the banner and nothing else. As Claude's closing put it: an operator-facing lie.

---

## Part II — What genuinely held

The council was not uniformly negative, and three eliminations were confirmed as real by seats that had every incentive to find holes in them.

- **Phantom execution is dead by type contract.** `ExecutionReceipt.__post_init__` raises at construction if the outcome is `EXECUTED` without a provider reference. A fabricated execution is not a bug that can be committed — the object cannot be built. Confirmed at `app/integrations/base.py:67-75`.
- **Cross-tenant event suppression is fixed at the schema.** The `events` primary key is `(tenant_id, event_digest, trust_level)`. One tenant's event can no longer deduplicate another's. Confirmed at `app/storage/db.py:83`.

- **Auth/RBAC configuration divergence is eliminated by construction.** A single parser in `app/core/config.py` is read by both layers, so they cannot disagree. It rejects duplicate key material at startup rather than resolving it silently.
- **Fail-closed authentication.** With no keys configured, every authenticated route returns 503. Deliberate, documented, and tested.
- **Merkle domain separation.** Leaf and node hashes carry distinct prefixes, closing the CVE-2012-2459 second-preimage class.

The seats' criticism was directed at what surrounded these, not at the primitives themselves.

---

## Part III — Where the seats disagreed

Two dissents were recorded. Both narrowed a peer's claim; neither changed a vote.

**Claude against Codex** on retention. Codex ranked the 90-day retention contradiction as the most serious remaining defect. Claude demonstrated `apply_retention` has **zero production callers** — it appears only in the `__all__` list. Its own docstring, claiming it is *"applied on write, not a cron nobody runs,"* is false. The failure class Codex identified is real, but it reaches production through the fabricated-fact path (F2), not through retention.

**Claude against Antigravity** on the dashboard. Antigravity's opening said the dashboard shows *"exactly zero across all categories."* Claude showed `events_processed` and `unverified_events` count `FROM events`, which the ingest path does populate. The dashboard is self-contradictory rather than uniformly zero — a correction that makes the finding worse, not better.

The seats also split on the evidence ledger's strategic value, though not on the vote. All three voted NO on it as a moat. Antigravity was bluntest: *"Local hash chain is standard; anchoring to public testnet is a gimmick."*

---

## Part IV — Market position

The external research brief (`council/brief.md`) is preserved in full. Its load-bearing conclusions, which the seats used and none contested:

- **The threat is real and correctly targeted.** Agent-directed prompt injection, tool-abuse and inter-agent compromise are the dominant 2026 attack classes, and OWASP's Agentic Security Initiative has standardised the taxonomy Sentinel maps to.
- **The category has already consolidated.** Palo Alto, Check Point (Lakera), SentinelOne (Prompt Security) and Cisco own runtime agent guardrails. This is not a greenfield market; it is a market with incumbents who ship.
- **The exploitable opening is consolidation refugees.** CISOs stranded by acquisitions want a focused tool that stays focused. Codex and Claude both identified this as the only credible wedge — and both noted the codebase shows no sign of pursuing it.
- **0.643 recall is disqualifying.** On a 22-case hand-authored corpus, with prompt-injection recall at 0.25. Codex re-ran the harness independently and reproduced the numbers. Against funded incumbents, a 35% miss rate is not a starting point to improve from; it is a reason not to start.

The commercially honest read, which two seats reached separately: this is not a company yet. It is a design-partner project, and company formation should be contingent on efficacy evidence that does not

currently exist.

---

## Part V — What has been fixed since the vote

All five findings are closed. Each fix targets the failure *class*, not the instance, and each is pinned by tests that fail if the defect returns.

| # | Finding | Fix | Proof |
|---|---|---|---|
| F1 | Queue transposition | `QueuedIncident(NamedTuple)`; consumers access by name, never by position | 4 tests |
| F2 | Fabricated lifecycle facts | `ArtifactMissing` — transitions verify the row exists **inside the transaction** | 3 tests |
| F3 | Metrics split-brain | All aggregates read `incident_state`; the dead `incidents` table has no readers | 3 tests |
| F4 | Undefined `run_id` | Removed; an AST test scans every route for undefined references | 1 test |
| F5 | Postgres banner | `app/storage/adapter.py` — `_connect()` opens a real psycopg connection | 7 tests |
| — | Webhook proof-of-execution | Receiver must return an HMAC bound to `(correlation_id, reference)` | 4 tests |

**F1 — positional coupling made impossible.** A tuple whose fields are addressed by index lets a producer and consumer disagree silently. `QueuedIncident` is a `NamedTuple`; the worker reads `task.tenant_id` and `task.incident_id`. Transposition is no longer expressible.

**F2 — the claim is now true.** `repository.transition()` runs `_ARTIFACT_PROOFS`: reaching `EVIDENCE_STORED` requires a matching row in `evidence`; `REPORTED` and `COMPLETED` require one in `reports`. The check runs inside the same transaction as the state write, so it cannot be raced. `report_id: "imaginary"` now raises `ArtifactMissing`. The v2 report bug is *now* structurally unreachable — the claim V3 made prematurely.

**F5 — Postgres is wired, and fails loudly.** `db._connect()` routes through `app/storage/adapter.py`, which opens a real `psycopg` connection, translates the canonical SQL (`?`→`%s`, `AUTOINCREMENT`→`BIGSERIAL`, `INSERT OR IGNORE`→`ON CONFLICT DO NOTHING`, `json_extract`→`::jsonb ->>`), and swaps `BEGIN IMMEDIATE` for `SELECT … FOR UPDATE` on the repository's read-modify-write transition. Verified live:

```
$ SENTINEL_DATABASE_URL=postgresql://…:5432/sentinel python -c "…"
engine resolves to: postgresql
PostgresUnavailable: could not connect to postgresql://127.0.0.1:5432/sentinel:
  ConnectionTimeout … Sentinel will NOT fall back to SQLite
```

It **attempted a real connection**. Before the fix, this call returned a working SQLite handle. Crucially it raises rather than degrading: a security product that silently changes where its evidence lives is worse than one that refuses to start.

**Webhook execution proof.** The seats noted that a 2xx plus a self-declared reference is not evidence — the receiver chooses that string, so anything answering `200 {"reference": "x"}` could mint an `EXECUTED` receipt, including a captive portal or an attacker who learns the URL. The endpoint must now return

`X-Sentinel-Receipt-Signature`: an HMAC over `(correlation_id, reference)` under the shared secret. That proves the responder holds the secret **and** saw this exact request, and it does not replay across correlation ids. Absent or invalid, the receipt is `FAILED` with the reason stated.

**Test suite: 140 → 152 passing.** The twelve new tests cover exactly the two fixes the seats ranked highest among open work.

---

# Part VI — What is still not true

This section exists because every previous report's worst failure was in what it left out.

**Not implemented at all.** Redis, Kafka, SAML, SCIM, mTLS/x509, leader election, and a Helm chart. Redis appears in `docker-compose.yml` and nothing reads from it. mTLS existed only as a docstring title. These were previously overstated as "built" in an earlier summary; that was wrong, and the correction is recorded here rather than dropped.

**Implemented but never exercised against live infrastructure.** The PostgreSQL path is wired and unit-tested, but no live server has been reached from this environment — there is no container runtime available. OIDC, the DLQ and OpenTelemetry are initialised and unit-tested, but never run against a real IdP, broker or collector. Kubernetes manifests have never been applied to a cluster.

**Not improved.** Detection recall remains **0.643** on a 22-case corpus, with prompt-injection recall at 0.25. No remediation pass has touched this, and all three seats identified it as the defect that matters most commercially. Plumbing was fixed; efficacy was not.

**Not verified by any seat.** ECDSA recovery correctness in `keys.recover_address` (read, not audited). Whether any Kubernetes pod boots. Whether webhook actions correspond to real provider state at the far end.

**A credential requires rotation, by the user.** A key of the form `sk-synth-…` was removed from the working tree but **still exists inside** `sentinel_soc-main.zip` **in the Downloads folder** (confirmed by scanning all 116 archives there; exactly one hit). It must be rotated at the issuing service. I did not delete the archive and cannot rotate the key.

---

# Part VII — The 90-day plan

Merged from all three seats, ordered by their combined priority. Items 1–4 are complete; the ranking is preserved so the sequence the council actually recommended stays visible.

1. ~~Fix the transposition; add an integration test that ingests **through the queue**~~ — done, 4 tests.
2. ~~Delete the second incident store; route all metrics through one authority~~ — done, 3 tests.
3. ~~Referential integrity for lifecycle facts~~ — done, `ArtifactMissing`, 3 tests.
4. ~~Wire Postgres for real, or delete the engine and stop printing the banner~~ — wired, 7 tests; **still unproven against a live server**.
5. **Move recall off 0.643 on an independent corpus.** Expand well beyond 22 hand-authored cases; blind the test set; add multilingual and obfuscated injection; stop labelling misses `known_gap` to keep CI green. Weeks, ongoing. **Not started.**

Beyond the plan, the seats were consistent that infrastructure is not the bottleneck. Claude: the plumbing failures are *"recoverable in a quarter; they are not the reason this isn't a company."*

## Part VIII — Honest bottom line

Three vendors' frontier models, given filesystem access and three rounds to argue, reached unanimous agreement on all eight votes. Not viable as a product. Not viable as a company. Not safe for a pilot. Not honest about its own state.

The fixes since the vote are real and independently pinned by tests, and they close the specific defects that made the code non-functional. What they do not do is change the verdict. The seats did not vote NO because of a transposed tuple; they voted NO because a detection product that misses 35% of what it is pointed at has no wedge against incumbents who ship, and because a system whose remediation passes keep re-introducing the same class of failure has not yet demonstrated it can be trusted to know its own state.

The most valuable output of this review is not the bug list. It is the pattern the council named: **three consecutive remediations, each eliminating the defects it was shown and introducing fresh instances of the same class.** V3's response was to make dishonest states structurally unrepresentable — the receipt type, the artifact proofs, the named tuple. That is the right instinct, and where it was applied the class genuinely died. It was simply not applied widely enough, and it was claimed before it was true.

The remaining work is not architectural. It is evidence: recall on a corpus nobody here authored, one boot against a live database, one incident processed end-to-end in something that is not a test harness.

## Appendix A — Verification method

Every finding in Part I was reproduced against running code before publication. No finding rests on a seat's reading of a docstring; the review's central lesson is that docstrings in this repository have asserted things the code did not do.

Fixes were verified by executing the failing case, applying the change, and re-executing. The Postgres verification is quoted verbatim in Part V, including its failure output, because a fix that cannot be shown failing correctly has not been shown at all.

One verification script produced a **false positive** during this work — a grep for leader election matched the word "lease" in unrelated code. It is recorded here because a review that hides its own errors has no standing to report anyone else's.

## Appendix B — Artifacts

| Artifact | Path |
|---|---|
| Nine round transcripts, verbatim | `council/transcript/` |
| Run metadata, timings, seat availability | `council/transcript/run_summary.json` |
| External research brief | `council/brief.md` |
| Council orchestrator and seat drivers | `council/council.py`, `council/seats.py` |
| Antigravity agentapi seat | `council/antigravity_seat.py` |
| Regression tests for all findings | `tests/test_council_v3_regressions.py` |

| Artifact | Path |
|---|---|
| Previous reviews | `council/COUNCIL_REPORT_v1.*`, `council/COUNCIL_REPORT_v2.md` |
| Prior transcripts | `council/transcript_v1_prefix/`, `council/transcript_v2_archive/` |